LENTERA TEKNOLOGI — CYBER SECURITY ASSESSMENT SERVICE

Dashboard Deadstock / First Resources (FR) Group

INTERNAL WEB PENETRATION TESTING REPORT — 19 OKTOBER 2026

Target System	Dashboard Deadstock — https://deadstock.first-resources.com / 10.110.1.9:1100
DNS / Routing	CNAME lkt-infra.first-resources.com → A 10.100.2.64 (Infrastructure Masking)
Assessment Scope	Internal Non-Destructive Linear Web Pentest (OWASP Top 10 Alur Linear 1 Putaran)
Attacker / Audit Node	Internal Workstation Node (Linux Security Subsystem / RFC1918 Scope)
Access Level Tested	Unauthenticated Passive Recon, Network Probing, & Application Response Baseline
Classification	**CONFIDENTIAL — INTERNAL ENTERPRISE SECURITY ASSESSMENT**

1. EXECUTIVE SUMMARY / RINGKASAN EKSEKUTIF

English

On 19 October 2026, a focused, non-destructive internal web penetration test was conducted against the **Dashboard Deadstock** application across two endpoints: the primary domain https://deadstock.first-resources.com (resolving via CNAME to 10.100.2.64) and the direct internal instance http://10.110.1.9:1100.

Testing operated under a linear, single-pass OWASP Top 10 methodology with strict zero-retry rules. Perimeter HTTPS defenses were verified to be solid, with valid commercial Sectigo TLS 1.3 encryption, active HSTS (max-age=86400), anti-clickjacking (X-Frame-Options: SAMEORIGIN), and MIME-type enforcement.

The primary observations identified are **F-01: Security Header Asymmetry on Port 1100 (Low)** and **F-02: Framework Disclosure (X-Powered-By: Express, Informational)**. An active port scan wrapper reached timeout (exit 124) and was recorded transparently as an information boundary.

Overall Assessment: Evidence confirms **1 Low-Risk Finding** and **1 Informational Observation**. Advanced authenticated categories remain unverified due to scope constraints.

Bahasa Indonesia

Pada 19 Oktober 2026 dilakukan pengujian penetrasi web internal non-destruktif terhadap sistem **Dashboard Deadstock** pada dua jalur akses: domain HTTPS utama https://deadstock.first-resources.com (ter-resolve via CNAME ke 10.100.2.64) dan instans server internal langsung http://10.110.1.9:1100.

Pengujian menerapkan alur linear satu putaran bebas macet sesuai standar OWASP Top 10. Pertahanan perimeter HTTPS terverifikasi kuat dengan enkripsi TLS 1.3 komersial Sectigo valid, HSTS aktif (max-age=86400), proteksi anti-clickjacking, dan penegakan tipe konten.

Temuan utama mencakup **F-01: Asimetri Header Keamanan pada Port 1100 (Low)** dan **F-02: Pengungkapan Framework (X-Powered-By: Express, Informational)**. Scan port Nmap mengalami batas waktu (exit 124) dan dicatat transparan sebagai batas informasi tanpa klaim port palsu.

Kesimpulan Umum: Hasil mendukung **1 Temuan Berisiko Rendah (Low)** dan **1 Observasi Informasional**. Kategori terautentikasi ditandai belum teruji sesuai batasan 1 putaran.

2. TARGET SYSTEM & ASSESSMENT PARAMETERS

English

Target 1 (Public Hostname): https://deadstock.first-resources.com
- DNS CNAME: lkt-infra.first-resources.com → A 10.100.2.64
- Transport / Web Stack: Nginx Reverse Proxy, TLSv1.3 with TLS_AES_256_GCM_SHA384
- Certificate: *.first-resources.com (Sectigo CA DV R36, valid 2026-06-29 to 2027-01-13)

Target 2 (Internal Direct Service): http://10.110.1.9:1100
- Network Type: Direct RFC1918 IPv4 Private Address (No PTR/DNS)
- Web Stack: nginx/1.22.1 + Node.js / Express (X-Powered-By: Express)
- Application Title: Dashboard Deadstock (First Resources Group)

Engagement Boundary: Isolated evaluation strictly for the Dashboard Deadstock application.

Bahasa Indonesia

Target 1 (Hostname Publik): https://deadstock.first-resources.com
- DNS CNAME: lkt-infra.first-resources.com → A 10.100.2.64
- Transport / Stack: Nginx Reverse Proxy, TLSv1.3 dengan TLS_AES_256_GCM_SHA384
- Sertifikat: *.first-resources.com (Sectigo CA DV R36, aktif 2026-06-29 s/d 2027-01-13)

Target 2 (Layanan Internal Langsung): http://10.110.1.9:1100
- Tipe Jaringan: Alamat Privat IPv4 RFC1918 Langsung (Tanpa PTR/DNS)
- Stack Web: nginx/1.22.1 + Node.js / Express (X-Powered-By: Express)
- Judul Aplikasi: Dashboard Deadstock (First Resources Group)

Batasan Engagement: Evaluasi terisolasi khusus untuk ruang lingkup aplikasi Dashboard Deadstock.

3. TESTING METHODOLOGY / METODOLOGI

English	Bahasa Indonesia
1. Passive Reconnaissance: DNS resolution via dig, CNAME mapping, httpx status check, and whatweb tech fingerprinting. **2. Targeted Network Scan:** Nmap scan (-sT --top-ports 100 -p1100 -T2). Process timed out at 180s (exit 124) and was recorded transparently without retry. **3. Application Response Probing:** Single-pass GET requests capturing headers and 2 KiB body samples across both targets into app_responses.txt. **4. TLS & Header Auditing:** OpenSSL s_client TLS 1.3 verification, HSTS validation, framing inspection, and asymmetry mapping. **5. Evidence Synthesis:** Separation of factual evidence from tooling artifacts and untested OWASP categories.	**1. Reconnaissance Pasif:** Resolusi DNS via dig, pemetaan CNAME, validasi status via httpx, dan fingerprinting teknologi via whatweb. **2. Scan Jaringan Terarah:** Nmap (-sT --top-ports 100 -p1100 -T2). Proses mencapai batas 180s (exit 124) dan dicatat transparan tanpa pengulangan. **3. Analisis Respons Aplikasi:** Permintaan GET satu kali menangkap header dan sampel body 2 KiB pada kedua target ke app_responses.txt. **4. Audit TLS & Header:** Verifikasi OpenSSL s_client TLS 1.3, validasi HSTS, inspeksi framing, dan pemetaan asimetri header. **5. Sintesis Bukti:** Pemisahan tegas antara temuan nyata, keterbatasan alat, dan kategori OWASP yang belum teruji.

4. RISK MATRIX & FINDINGS OVERVIEW / MATRIKS RISIKO & TEMUAN

Finding ID	Security Issue / Isu Keamanan	Severity	Status / Verification Note
F-01	**Security Header Asymmetry & Unhardened HTTP Port 1100** *Asimetri Header Keamanan & Ketiadaan Hardening Port 1100 HTTP*	**LOW**	Configuration Flaw (CWE-16/1021) *Kelemahan Konfigurasi*
F-02	**Backend Framework & Server Version Disclosure** *Pengungkapan Framework Backend & Versi Server (X-Powered-By: Express)*	**INFO**	Technology Exposure (CWE-200) *Eksposur Informasi*
O-01	**Network Port Scan Execution Timeout (Exit 124)** *Batas Waktu Eksekusi Scan Port Nmap (Exit 124)*	**INFO**	Scope Limitation Recording *Catatan Keterbatasan Informasi*
O-02	**Incomplete Local Environment TLS Trust Store (Verify Code 21)** *Ketidaklengkapan Trust Store TLS Lokal (Verify Code 21)*	**INFO**	Local Client Artifact *Artefak Lingkungan Penguji*

5. DETAILED FINDINGS BREAKDOWN / RINCIAN TEMUAN

F-01: Security Header Asymmetry & Unhardened HTTP Port 1100

English	Bahasa Indonesia
Risk Rating: LOW | **CWE:** CWE-16 / CWE-1021 | **Status:** Verified Flaw	**Risk Rating:** LOW | **CWE:** CWE-16 / CWE-1021 | **Status:** Kelemahan Terverifikasi
Impact: Direct access to http://10.110.1.9:1100 omits baseline defensive headers (Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options, CSP). Although no cleartext credential form was observed on the sampled payload, leaving the internal socket accessible without hardening creates potential exposure.	**Dampak:** Akses langsung ke http://10.110.1.9:1100 tidak menyertakan header pertahanan standar (HSTS, X-Frame-Options, X-Content-Type-Options, CSP). Kendati tidak teramati adanya form login berpassword pada sampel 2 KiB, ketiadaan proteksi pada socket internal membuka potensi risiko.
Detailed Narrative: Probing confirmed that the HTTPS reverse proxy correctly applies defensive headers, but direct internal connections to port 1100 receive plain caching headers only. This asymmetry indicates defenses exist solely at the outer edge proxy.	**Deskripsi Rinci:** Hasil audit membuktikan reverse proxy HTTPS menerapkan header keamanan dengan baik, namun akses langsung ke port 1100 hanya menghasilkan header cache. Asimetri ini menunjukkan proteksi hanya berada di lapisan luar reverse proxy.
Recommended Remediation: 1. Bind port 1100 strictly to 127.0.0.1:1100, forcing all traffic via HTTPS reverse proxy. 2. If direct access is required, inject standard security headers directly in Express/Nginx. 3. Enforce automatic HTTP 301 redirection to HTTPS.	**Rekomendasi Perbaikan:** 1. Batasi binding port 1100 hanya ke 127.0.0.1:1100 dan alihkan seluruh trafik via reverse proxy HTTPS. 2. Pasang header keamanan standar langsung pada konfigurasi Express/Nginx backend bila akses langsung dibutuhkan. 3. Terapkan pengalihan otomatis 301 ke HTTPS.

```
$ curl -I http://10.110.1.9:1100/
HTTP/1.1 200 OK
Server: nginx/1.22.1
X-Powered-By: Express
Content-Type: text/html; charset=UTF-8
(Missing: Strict-Transport-Security, X-Frame-Options, X-Content-Type-Options)

$ curl -k -I https://deadstock.first-resources.com/
HTTP/1.1 200 OK
Server: nginx
Strict-Transport-Security: max-age=86400
X-Frame-Options: SAMEORIGIN
X-Content-Type-Options: nosniff
```

F-02: Backend Framework & Server Version Disclosure

English	Bahasa Indonesia
Risk Rating: INFORMATIONAL | **CWE:** CWE-200 | **Status:** Verified Exposure	**Risk Rating:** INFORMATIONAL | **CWE:** CWE-200 | **Status:** Eksposur Terverifikasi
Impact: Responses from port 1100 reveal X-Powered-By: Express and Server: nginx/1.22.1. While not an exploitable vulnerability alone, it aids attackers in fingerprinting the stack.	**Dampak:** Respons port 1100 mengekspos X-Powered-By: Express dan Server: nginx/1.22.1. Walaupun bukan celah langsung, informasi ini mempermudah pemetaan teknologi target oleh penyerang.
Remediation: Declare app.disable('x-powered-by') in Express and set server_tokens off; in Nginx.	**Rekomendasi Perbaikan:** Tambahkan app.disable('x-powered-by') pada Express dan server_tokens off; pada Nginx.

6. ADDITIONAL SECURITY OBSERVATIONS & TELEMETRY

English	Bahasa Indonesia
O-01 (Port Scan Timeout): Subtask 194 Nmap scan reached the 180-second terminal harness limit (exit 124) due to conservative -T2 timing over 2 hosts. In compliance with anti-loop rules, it was logged to recon_errors.txt without retry.	**O-01 (Batas Waktu Scan Port):** Subtask 194 Nmap mencapai batas waktu 180s (exit 124) akibat profil waktu -T2 pada 2 target. Sesuai protokol anti-loop, kejadian dicatat pada recon_errors.txt tanpa perulangan.
O-02 (Local TLS Verify-21): OpenSSL returned verify code 21 due to absent intermediate CA bundle on the tester workstation. The public Sectigo certificate is legitimately valid through January 2027.	**O-02 (TLS Verify-21 Lokal):** OpenSSL menghasilkan verify code 21 akibat belum tersinkronisasinya intermediate CA pada workstation penguji. Sertifikat publik Sectigo terbukti valid dan resmi hingga Januari 2027.

7. VERIFIED CONTROLS & NEGATIVE TEST RESULTS / KONTROL TERVERIFIKASI

Security Parameter & Verified Control (English)	Hasil Verifikasi & Kontrol Keamanan (Bahasa Indonesia)
TLS 1.3 Cryptography: Modern TLSv1.3 negotiated with cipher TLS_AES_256_GCM_SHA384 and X25519 key exchange.	**Kriptografi TLS 1.3:** TLSv1.3 modern ternegosiasi dengan cipher kuat TLS_AES_256_GCM_SHA384 dan pertukaran kunci X25519.
HSTS Enforcement: Strict-Transport-Security header active on HTTPS with max-age=86400.	**Penerapan HSTS:** Header Strict-Transport-Security aktif pada HTTPS dengan parameter durasi max-age=86400.
Anti-Clickjacking Framing: X-Frame-Options: SAMEORIGIN enforced on public HTTPS endpoint.	**Kebijakan Anti-Clickjacking:** Header X-Frame-Options: SAMEORIGIN aktif pada HTTPS mencegah framing ilegal.
MIME Sniffing Defense: X-Content-Type-Options: nosniff enforced on HTTPS.	**Proteksi MIME Sniffing:** Header X-Content-Type-Options: nosniff aktif pada HTTPS menolak sniffing tipe konten.
Infrastructure Masking: DNS CNAME routes to lkt-infra.first-resources.com (10.100.2.64), isolating backend IP.	**Masking Infrastruktur:** CNAME DNS mengarah ke lkt-infra.first-resources.com (10.100.2.64), menyamarkan IP backend langsung.

8. TESTING LIMITATIONS & UNTESTED BOUNDARIES / BATASAN PENGUJIAN

English	Bahasa Indonesia
• **Linear Single-Pass Constraint:** Adhered to strict non-destructive parameters (max 1 probe per tool, no retries, no crawling). • **Network Service Gap:** Nmap timed out at 180s; open port and service version mapping across the host remains incomplete. • **Body Sampling Threshold:** Body capture was constrained to a 2 KiB sample size; hidden form inputs were not audited. • **Authentication Untested:** No login sessions, cookie flags, or CORS handling were evaluated. • **Advanced OWASP Categories:** Broken Access Control (A01), Injection (A03), and Components (A06) were not audited. • **Zero Destructive Impact:** No brute-forcing, SQL injection fuzzing, or DoS testing was conducted.	• **Batasan Alur Linear 1 Putaran:** Pengujian mengikuti batasan non-destruktif ketat (maksimal 1 percobaan per alat, tanpa retry, tanpa crawling). • **Keterbatasan Scan Jaringan:** Nmap mengalami timeout pada 180 detik; pemetaan seluruh port dan versi layanan belum lengkap. • **Batas Sampel Body:** Sampel HTML dibatasi hingga 2 KiB; elemen form tersembunyi tidak diinspeksi. • **Autentikasi Belum Teruji:** Tidak ada sesi login, flag cookie, atau kebijakan CORS yang dievaluasi. • **Kategori OWASP Lanjutan:** Broken Access Control (A01), Injeksi (A03), dan Komponen Usang (A06) belum diaudit. • **Bebas Uji Destruktif:** Tidak dilakukan brute-force, fuzzing SQL, atau pengujian denial-of-service.

9. ACTIONABLE REMEDIATION ROADMAP / PANDUAN PERBAIKAN

English	Bahasa Indonesia
1. Harden and Restrict Internal HTTP Port 1100 — Priority: **LOW / MEDIUM** Rebind internal service on 10.110.1.9 to 127.0.0.1:1100 and enforce all access through the HTTPS reverse proxy.	**1. Hardening dan Isolasi Port 1100 HTTP Internal** — Prioritas: **LOW / MEDIUM** Ubah binding layanan internal ke 127.0.0.1:1100 dan alihkan seluruh akses melalui reverse proxy HTTPS.
2. Suppress Technology Signatures — Priority: **INFORMATIONAL** Declare app.disable('x-powered-by') in Express and configure server_tokens off; in Nginx.	**2. Sembunyikan Informasi Framework** — Prioritas: **INFORMATIONAL** Tambahkan app.disable('x-powered-by') pada Express dan server_tokens off; pada Nginx.
3. Investigate Nmap Scan Timeout — Priority: **INFORMATIONAL** Analyze network rate limiting or drop rules causing the 180s Nmap timeout; conduct optimized -T4 scans.	**3. Investigasi Timeout Scan Port Nmap** — Prioritas: **INFORMATIONAL** Analisis latency atau filter firewall yang menyebabkan timeout 180s; lakukan pemindaian terarah dengan profil -T4.
4. Synchronize CA Trust Stores & Phase-2 Audit — Priority: **INFORMATIONAL** Install intermediate CAs in local trust stores and schedule authenticated Phase-2 testing for OWASP logic.	**4. Sinkronisasi Trust Store CA & Asesmen Lanjutan** — Prioritas: **INFORMATIONAL** Pasang intermediate CA pada workstation lokal dan jadwalkan pengujian terautentikasi untuk memeriksa logika OWASP.

10. CONCLUSION / KESIMPULAN

English	Bahasa Indonesia
Within the executed linear single-pass scope, the **Dashboard Deadstock** application exhibits a robust external security posture on its primary HTTPS domain, featuring modern TLS 1.3 cryptography, active HSTS enforcement, and anti-clickjacking framing controls. No high or critical severity vulnerabilities were demonstrated within the unauthenticated test boundary. Defensive optimizations should focus on hardening internal port 1100 to mirror edge policies, suppressing framework banners, and planning credentialed assessments for post-login workflows.	Dalam batasan pengujian linear satu putaran yang dilakukan, aplikasi **Dashboard Deadstock** menunjukkan postur keamanan eksternal yang tangguh pada domain HTTPS utamanya, didukung enkripsi TLS 1.3 modern, penerapan HSTS aktif, serta kontrol anti-clickjacking yang baik. Tidak ditemukan kerentanan berisiko tinggi (High) maupun kritis (Critical) pada batasan pengujian tanpa autentikasi ini. Optimasi difokuskan pada hardening port 1100 internal agar sejajar dengan kebijakan reverse proxy, penghapusan header framework, dan persiapan audit terautentikasi untuk alur kerja pasca-login.

Report Prepared By: Cyber Security Assessment Division Lentera Teknologi	**Classification:** CONFIDENTIAL — INTERNAL ONLY Zero Defect Assessment Standard	**Document Verification:** ECC Gate 1-5 Compliant Date: 19 Oktober 2026